Avril 2026

Rapport de TP

Règles de filtrage avancées et configuration du NAT sur OPNsense

Pape Aldiouma SARR
L2 Cybersecurite - Module : Sécurité Réseau

Rapport de travaux pratiques : alias, règles de filtrage LAN et WAN, Outbound NAT, Port Forward, NAT 1:1, analyse des logs de firewall et planification horaire des règles sous OPNsense.



Republique du Senegal, Un Peuple, Un But, Une Foi
Ministere de l'Enseignement Superieur, de la Recherche et de l'Innovation
Direction Generale de l'Enseignement Superieur Prive
Institut Superieur de Management
Année academique 2025-2026

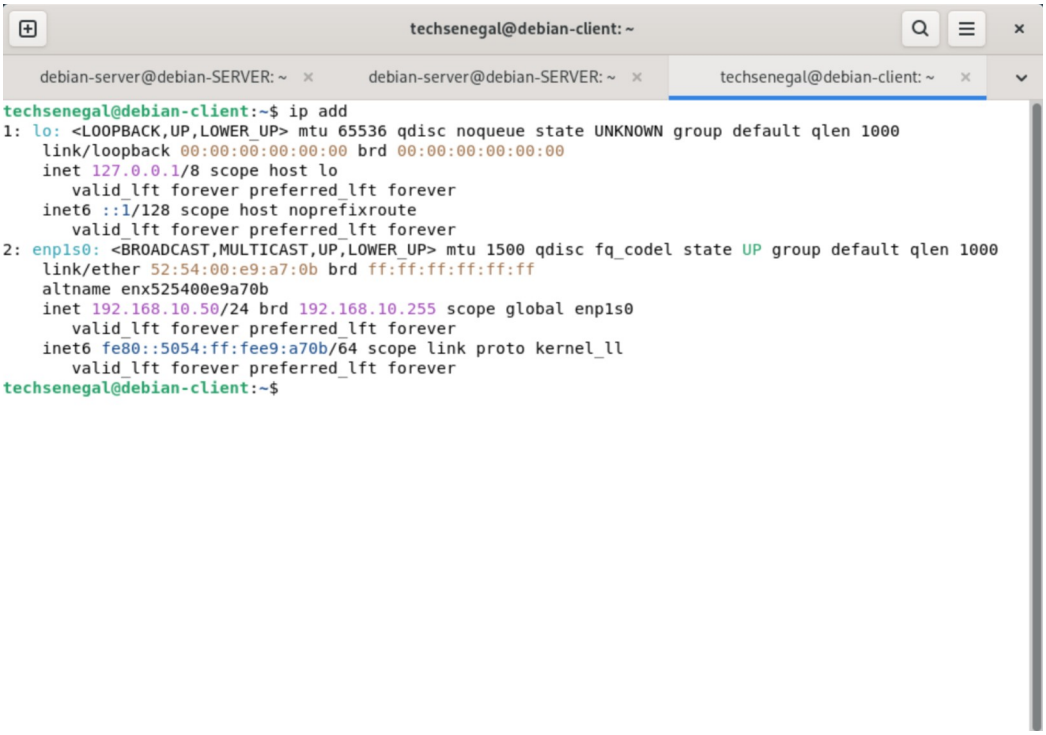
Table des matieres

Partie 0 : Architecture et préparation des VM..... 3
Partie 1 : Les alias..... 5
Partie 2 : Règles de filtrage LAN..... 6
Partie 3 : Règles WAN..... 7
Partie 4 : Configuration du NAT..... 8
Partie 5 : Tests et validation..... 11
Partie 6 : Analyse des logs de firewall..... 14
Partie 7 : Optimisations et bonnes pratiques..... 15
Mini-defi..... 15
Conclusion..... 17

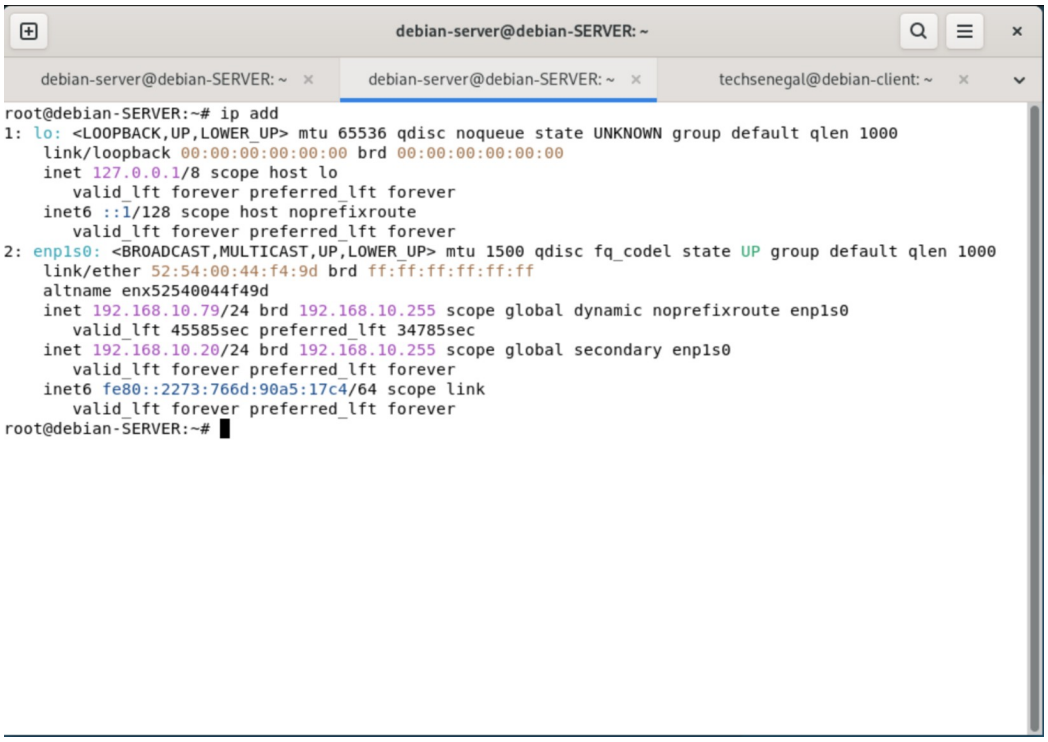
Partie 0 : Architecture et préparation des VM

0.1. Tableau des adresses IP configurees

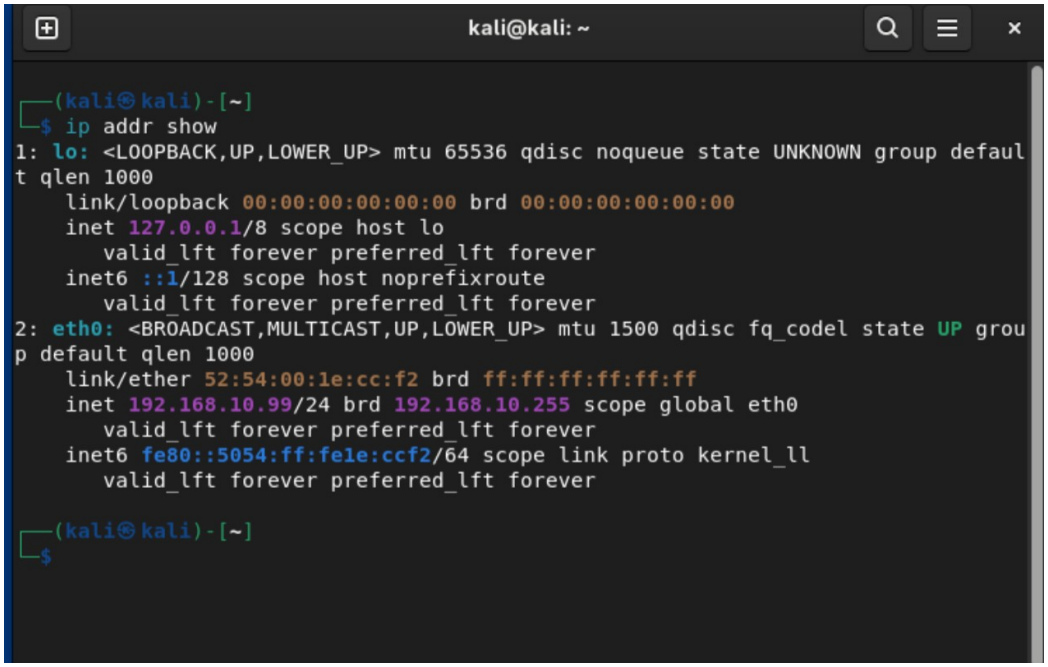
Machine	Rôle	IP configurée	Réseau QEMU
OPNsense	Pare-feu	WAN : 192.168.122.155 / LAN : 192.168.10.1	virbr0 (NAT) + virbr1
Debian Cliente	Poste admin	192.168.10.50	virbr1 (lan-opnsense)
Debian Server	Serveur web interne	192.168.10.20	virbr1 (lan-opnsense)
Kali Linux	Machine de test	192.168.10.99	virbr1 (lan-opnsense)



ip addr show sur Debian Cliente : confirme l'adresse 192.168.10.50/24.



ip addr show sur Debian Server : confirme l'adresse 192.168.10.20/24.

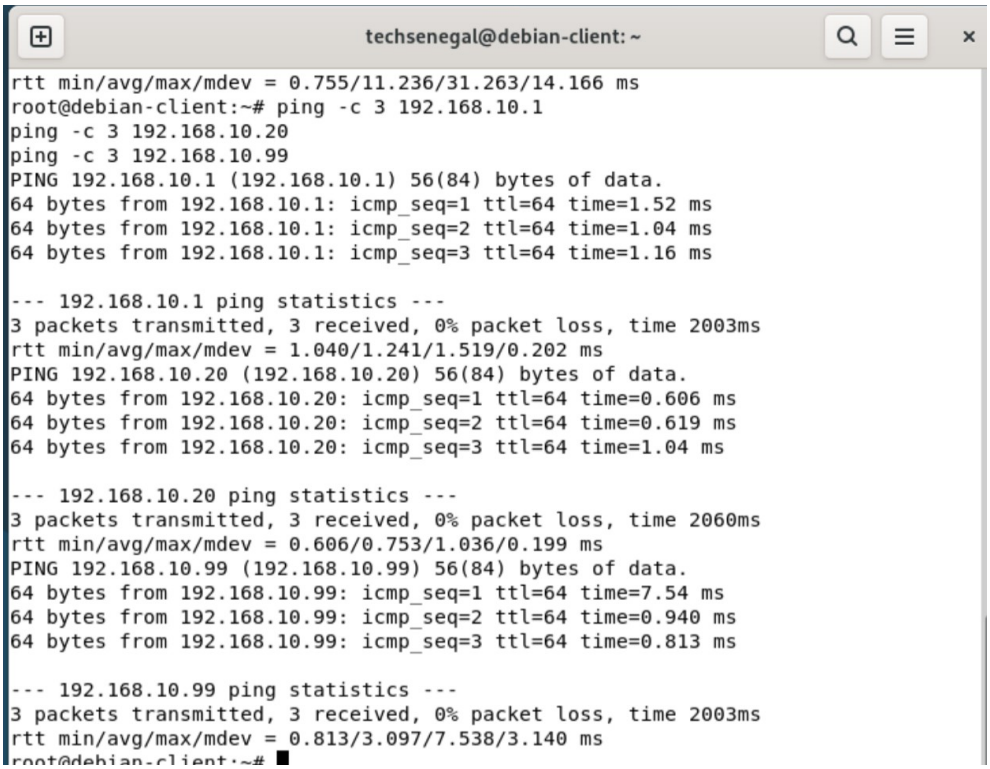


ip addr show sur Kali Linux : confirme l'adresse 192.168.10.99/24.

0.2. Connectivite initiale (avant les règles)

Que se passe-t-il quand toutes les VM se pinguent avant la création des règles ? Pourquoi ?

Avant la création des règles, toutes les machines peuvent communiquer librement entre elles : OPNsense ne filtre encore rien, et le trafic interne au réseau LAN est donc autorise par defaut.



Pings depuis Debian Cliente vers 192.168.10.1, .20 et .99 : tous reussis avant la création des règles.

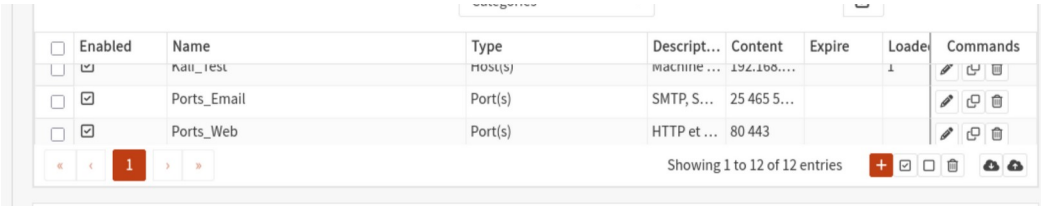
Partie 1 : Les alias

1.1. Pourquoi utiliser des alias ?

Les alias sont des noms que l'on attribue a des adresses IP, des réseaux ou des ports afin de les identifier plus facilement et de simplifier l'écriture des règles. C'est comparable a un contact enregistre dans un telephone : le nom représente ici l'alias, et la valeur réelle (l'adresse IP ou le port) reste associée en arriere-plan.

1.2. Alias créés

Nom de l'alias	Type	Valeur(s)	Rôle
Serveur_Web_Interne	Host(s)	192.168.10.20	Serveur Apache interne TechSenegal
Poste_Admin	Host(s)	192.168.10.50	Poste administrateur réseau
Kali_Test	Host(s)	192.168.10.99	Machine de test Kali Linux
Ports_Web	Port(s)	80, 443	HTTP et HTTPS
Ports_Email	Port(s)	25, 465, 587, 143, 993	SMTP, SMTPS, IMAP, IMAPS



Page Firewall > Aliases dans OPNsense montrant les 5 alias créés.

Partie 2 : Règles de filtrage LAN

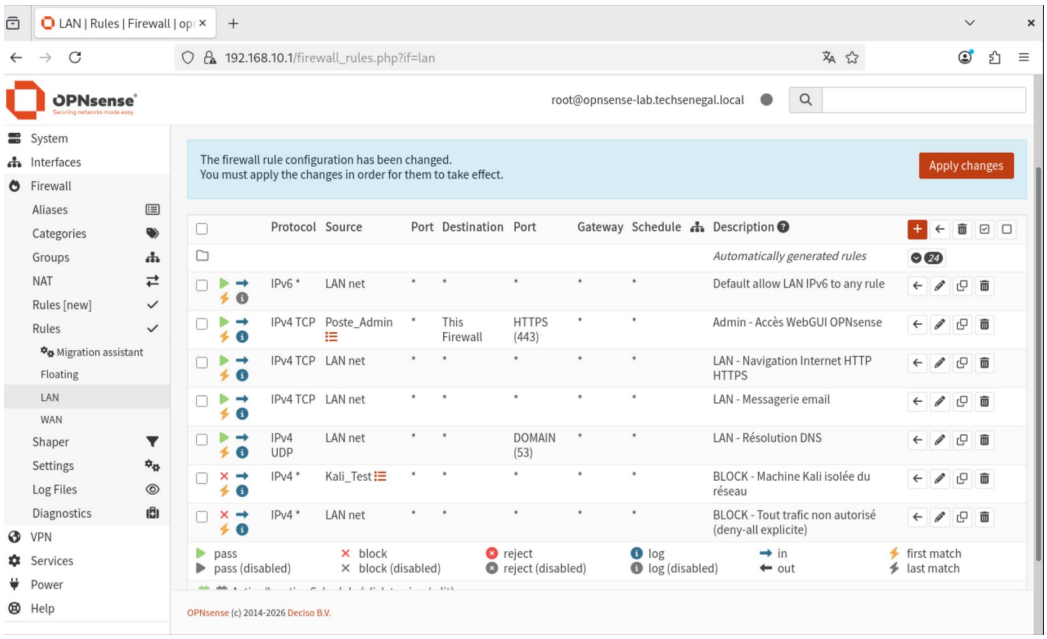
2.1. Logique de traitement des règles

Expliquez le principe du premier match gagne dans OPNsense. Pourquoi l'ordre des règles est-il crucial ?

Sur OPNsense, comme sur pfSense et la plupart des pare-feu a état, le traitement des règles suit le principe du premier match gagne : chaque paquet est compare aux règles dans l'ordre, et des qu'une règle correspond, elle s'applique immédiatement sans evaluer les suivantes. L'ordre des règles est donc crucial : les règles les plus spécifiques et les plus importantes doivent être placees avant les règles générales, sous peine de ne jamais être appliquées.

2.2. Règles LAN configurees

#	Action	Source	Destination	Port	Justification
1	Pass	Poste_Admin	192.168.10.1	443 (HTTPS)	Admin vers WebGUI OPNsense
2	Pass	LAN net	Any	Ports_Web	Navigation Internet HTTP/HTTPS
3	Pass	LAN net	Any	Ports_Email	Messagerie electronique
4	Pass	LAN net	Any	53 UDP	Résolution DNS
5	Block	Kali_Test	Any	Any	Bloquer Kali Linux
6	Block	LAN net	Any	Any	Deny-all explicite



Page Firewall > Rules > LAN montrant les 6 règles dans l'ordre correct.

2.3. Pourquoi une règle speciale pour le DNS ?

Le DNS doit être autorise séparément car il utilise un protocole différent (UDP/TCP port 53) des ports web (HTTP/HTTPS). Sans cette règle, la résolution des noms de domaine echoue, ce qui rend l'accès aux services Internet impossible même si les ports 80 et 443 sont ouverts.

2.4. Différence entre Block et Reject

L'option Reject est souvent préférée sur le réseau interne (LAN), car elle renvoie immédiatement une réponse (TCP RST ou ICMP unreachable), ce qui permet aux utilisateurs legitimes d'obtenir rapidement un échec explicite en cas de blocage plutôt que d'attendre un délai d'expiration.

Sur le WAN en revanche, il est preferable d'utiliser Block, qui ignore silencieusement le paquet : aucune information n'est renvoyée a un éventuel attaquant, ce qui limite sa capacité a cartographier le réseau.

Partie 3 : Règles WAN

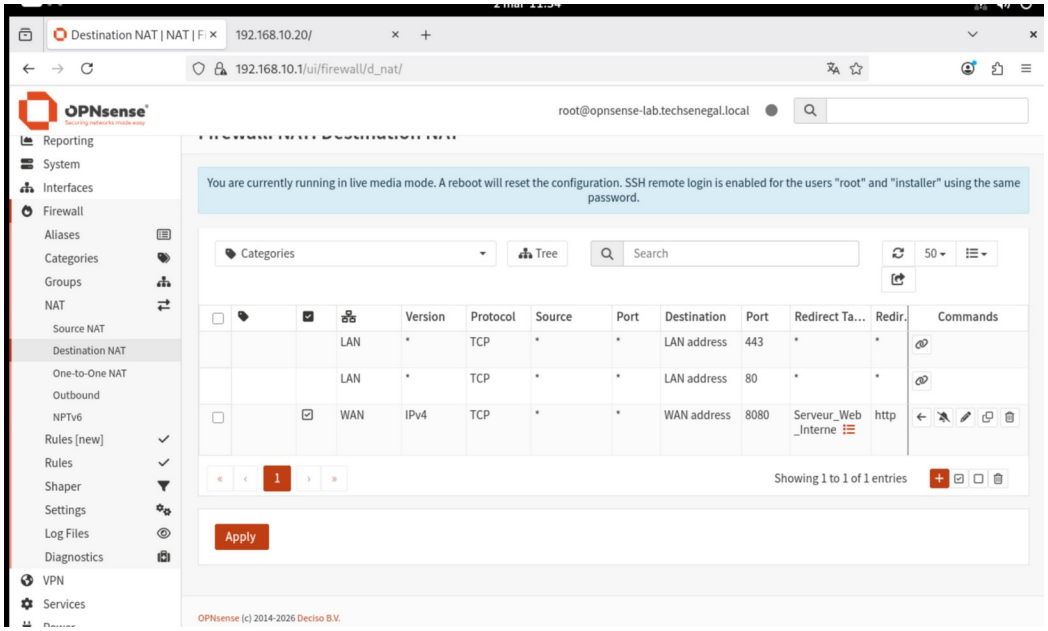
3.1. Comportement par defaut du WAN

Par defaut, OPNsense bloque tout le trafic entrant provenant d'Internet (WAN). Cette politique restrictive permet de limiter les risques, notamment face aux scans de ports venant de l'extérieur. C'est une bonne pratique de sécurité : n'autoriser que les accès strictement nécessaires.

3.2. Règle WAN générée automatiquement

Description de la règle WAN créée automatiquement lors de la configuration du Port Forward :

Le Port Forward seul ne suffit pas : il indique ou rediriger le trafic, mais sans règle WAN correspondante, OPNsense bloque le paquet avant même qu'il atteigne la redirection. La règle WAN joue le rôle de portier : elle autorise le paquet a entrer, puis le Port Forward le redirige vers la bonne machine interne.



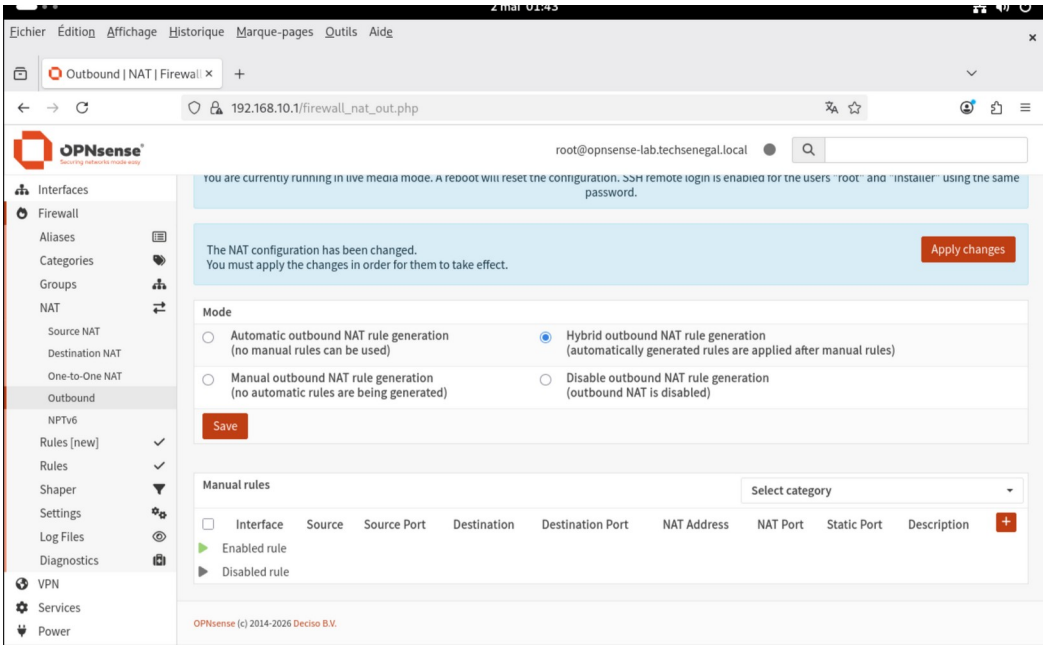
Page Firewall > NAT > Destination NAT listant les règles de Port Forward, dont celle du port 8080 vers Serveur_Web_Interne (HTTP) a l'origine de la règle WAN générée automatiquement.

Partie 4 : Configuration du NAT

4.1. Outbound NAT

L'Outbound NAT permet aux machines du réseau LAN (192.168.10.0/24) d'acceder a Internet en traduisant leurs adresses IP privees en l'adresse IP publique du WAN d'OPNsense. Sans lui, les paquets partiraient avec une IP privée non routable sur Internet et ne recevraient jamais de réponse.

Le mode Hybrid est le meilleur compromis : les règles automatiques garantissent que tout le trafic LAN sort correctement, tout en gardant la flexibilite d'ajouter des règles personnalisees si besoin.



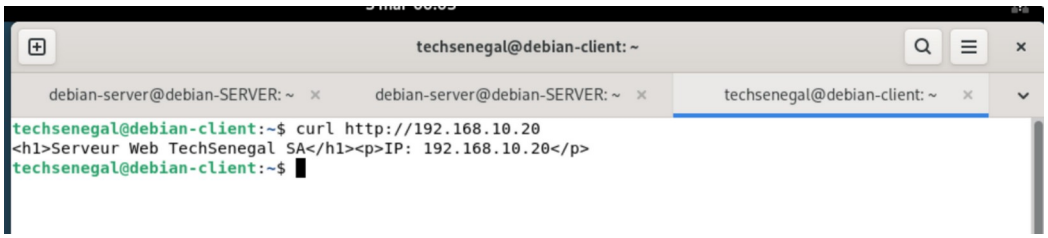
Page Firewall > NAT > Outbound en mode Hybrid avec les règles automatiques visibles.

4.2. Serveur web Apache sur Debian Server

Le serveur Apache répond-il correctement ? Comment l'avez-vous verifie ?

Apache n'était pas preinstalle sur la machine. Il a été installe manuellement depuis la VM Debian Server, utilisee ici comme serveur a la place d'Ubuntu Server qui ne fonctionnait pas correctement dans cet environnement, avec les commandes suivantes :

```
sudo apt update && sudo apt install -y apache2
sudo systemctl start apache2
sudo systemctl enable apache2
```



Résultat de curl http://192.168.10.20 depuis Debian Cliente : page Apache TechSenegal.

4.3. Port Forward WAN:8080 vers Debian Server:80

Description de la règle Port Forward créée :

Champ	Valeur configurée
Interface	WAN
Protocol	TCP
Destination (IP WAN)	WAN address
Port public expose	8080
Redirect target IP	Serveur_Web_Interne

Champ	Valeur configurée
Redirect target port	HTTP (80)



Page Firewall > NAT > Port Forward avec la règle WAN:8080 vers 192.168.10.20:80.

4.4. Test du Port Forward

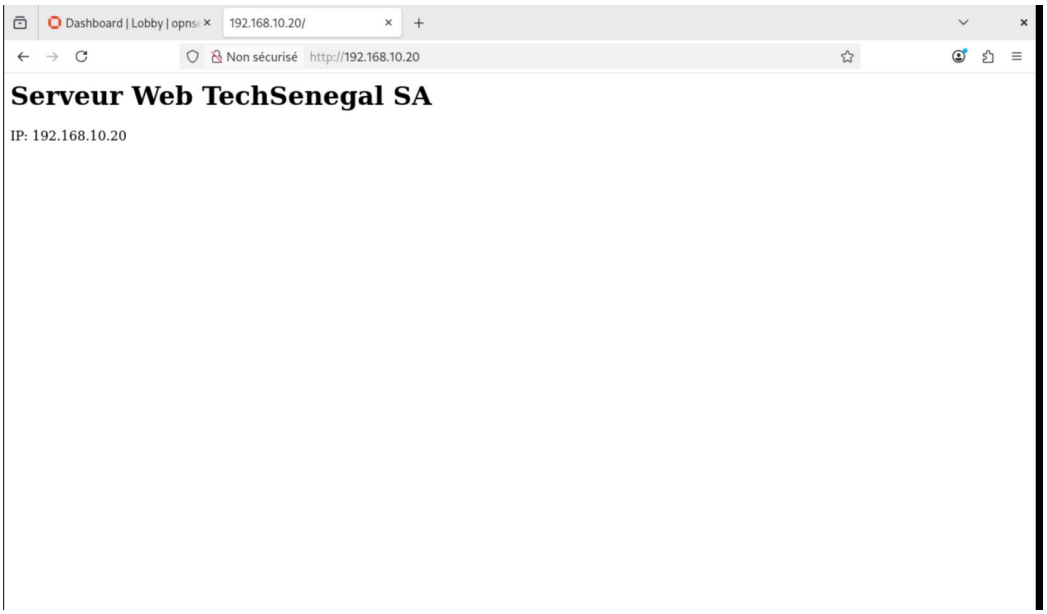
Comment avez-vous teste le Port Forward depuis l'extérieur ? Quelle commande et quel résultat ?

Pour simuler un accès depuis Internet, la machine physique Ubuntu a été utilisee (elle dispose d'un accès au réseau NAT libvirt, 192.168.122.0/24).

L'adresse IP WAN d'OPNsense a d'abord été relevee dans la WebGUI, via Lobby -> Dashboard, widget Interfaces.

Depuis un terminal sur la machine hote Ubuntu, la commande suivante a été exécutée :

```
curl http://192.168.122.X:8080
```



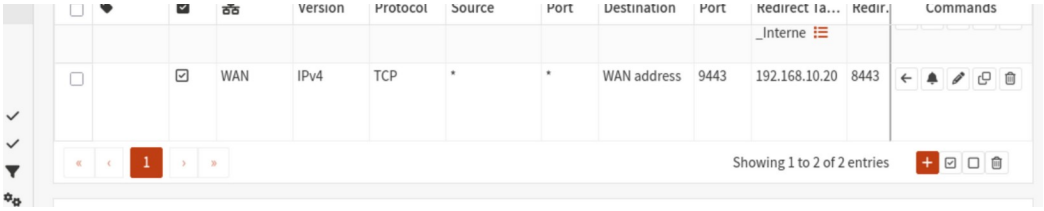
Page Apache TechSenegal affichee dans le navigateur, confirmant qu'Apache sert correctement le contenu sur Debian Server.

La barre d'adresse de cette capture indique http://192.168.10.20, c'est-a-dire l'adresse interne de Debian Server, et non l'adresse externe 192.168.122.X:8080 testée par la commande curl ci-dessus. Cette image confirme donc qu'Apache répond correctement sur le réseau interne, mais ne constitue pas a elle seule la preuve visuelle du test du Port Forward depuis l'extérieur : aucune capture de la commande curl http://192.168.122.X:8080 n'est disponible pour ce rapport.

4.5. Port Forward WAN:9443 vers Debian Server:8443 (defi)

Decrivez comment vous avez configure ce second Port Forward et les difficultés rencontrées.

La configuration a été réalisée via Firewall -> NAT -> Port Forward. Quelques difficultés ont été rencontrées lors de l'attribution du port 9443, notamment pour s'assurer qu'il ne rentrait pas en conflit avec une règle existante.



Page Firewall > NAT > Port Forward avec les deux règles (8080 et 9443).

Expliquez pourquoi le test depuis la machine hote Ubuntu echoue avec QEMU/KVM en mode NAT libvirt.

Le test depuis la machine hote sous Ubuntu echoue avec QEMU/KVM en mode NAT libvirt car ce mode isole les machines virtuelles derrière un réseau prive propre a libvirt (192.168.122.0/24), distinct du réseau WAN simule par OPNsense : la machine hote n'a donc pas une vue réseau identique a celle d'un client externe réel situe sur Internet.

4.6. NAT 1:1 (théorique)

Expliquez le principe du NAT 1:1. Dans quel cas réel l'utiliseriez-vous ? Pourquoi n'est-il pas testable dans ce lab ?

Le NAT 1:1 (One-to-One NAT) consiste a associer une adresse IP publique dédiée a une adresse IP privée interne. Chaque paquet recu sur cette IP publique est directement redirige vers une seule machine interne, et inversement pour le trafic sortant.

Ce mécanisme est utilise en pratique lorsqu'un serveur interne doit être entièrement expose sur Internet avec sa propre adresse publique, par exemple un serveur de messagerie ou un serveur applicatif critique, plutôt que de rediriger port par port comme avec un Port Forward classique.

Il n'est pas testable dans ce laboratoire car OPNsense ne dispose ici que d'une seule adresse IP WAN, elle-même attribuee par le NAT de libvirt (192.168.122.0/24) : il n'y a donc pas de second bloc d'adresses IP publiques disponible a associer de manière exclusive a une machine interne.

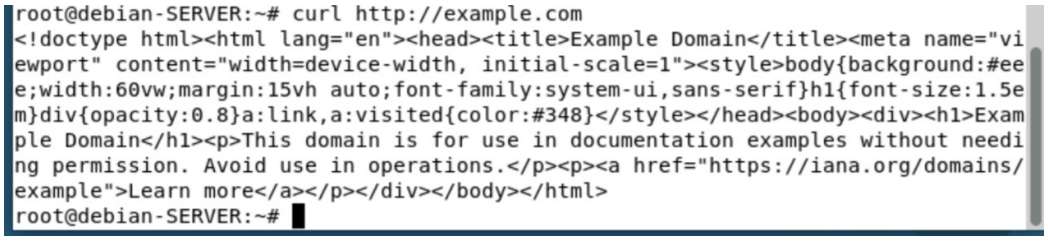
Partie 5 : Tests et validation

5.1. Tableau de validation

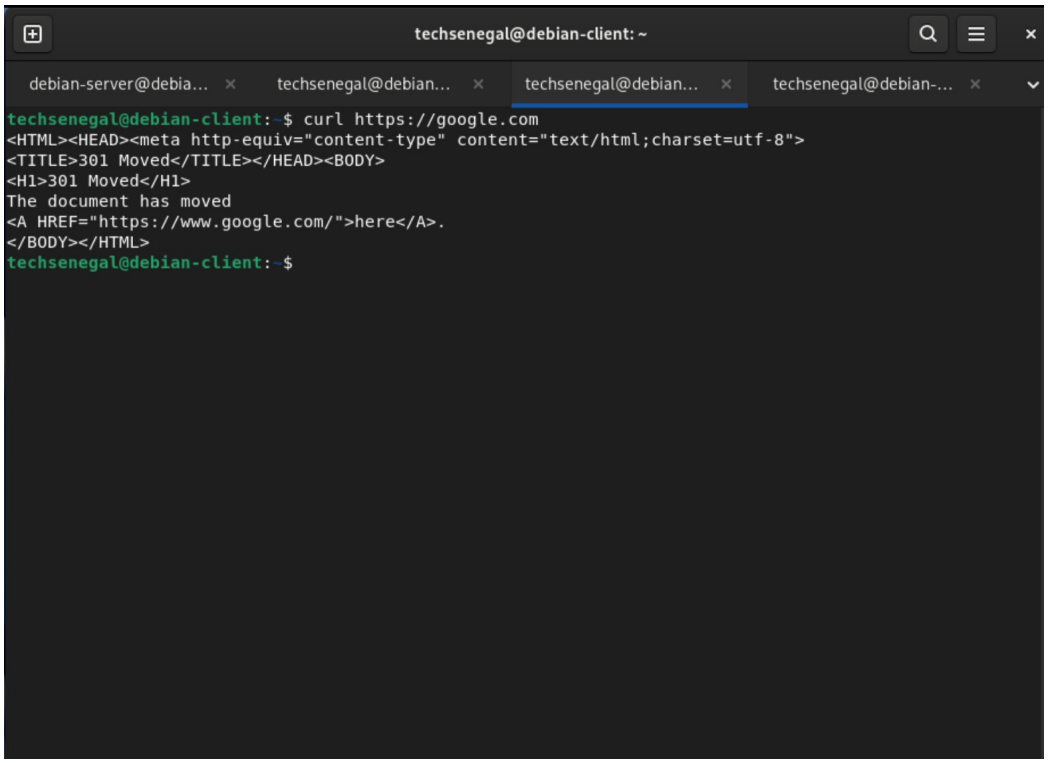
Test	Source	Destination:port	Résultat obtenu
Navigation HTTP	Debian Cliente	example.com:80	Réussi
Navigation HTTPS	Debian Cliente	google.com:443	Réussi
DNS	Debian Cliente	8.8.8.8:53 UDP	Résolu

Test	Source	Destination:port	Résultat obtenu
FTP bloque	Debian Cliente	ftp.gnu.org:21	Timeout
Kali vers Internet	Kali Linux	8.8.8.8:any	Bloque
Kali vers WebGUI	Kali Linux	192.168.10.1:443	Bloque
Admin vers WebGUI	Debian Cliente	192.168.10.1:443	Accès OK
Port Forward 8080	Machine hote	IP_WAN:8080	Page Apache
Port Forward 9443	Machine hote	IP_WAN:9443	Serveur HTTP Python

5.2. Test navigation HTTP/HTTPS depuis Debian Cliente

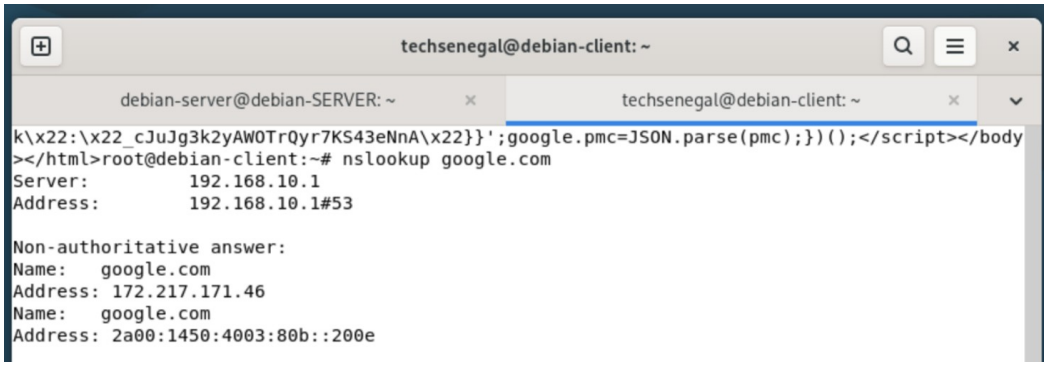


Résultat de curl http://example.com depuis Debian Cliente : connexion réussie.



Résultat de curl https://google.com depuis Debian Cliente : connexion réussie (redirection HTTP vers www.google.com).

5.3. Test DNS

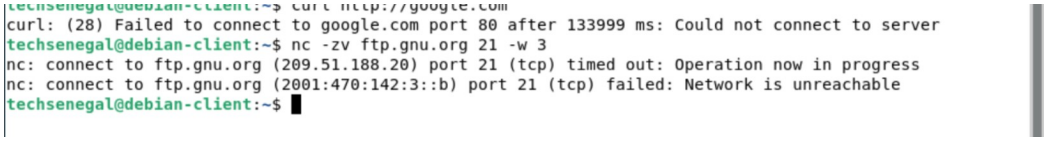


Résultat de nslookup google.com depuis Debian Cliente : résolution DNS réussie.

Que se passerait-il si la règle DNS (UDP/53) n'existait pas, même avec les règles HTTP/HTTPS actives ?

Les machines du LAN ne pourraient plus resoudre les noms de domaine. La navigation web serait impossible en pratique, même si les ports 80 et 443 sont autorises, car un navigateur effectue toujours une requête DNS en UDP/53 pour traduire un nom de domaine en adresse IP avant d'établir la connexion HTTP ou HTTPS.

5.4. Test FTP bloque

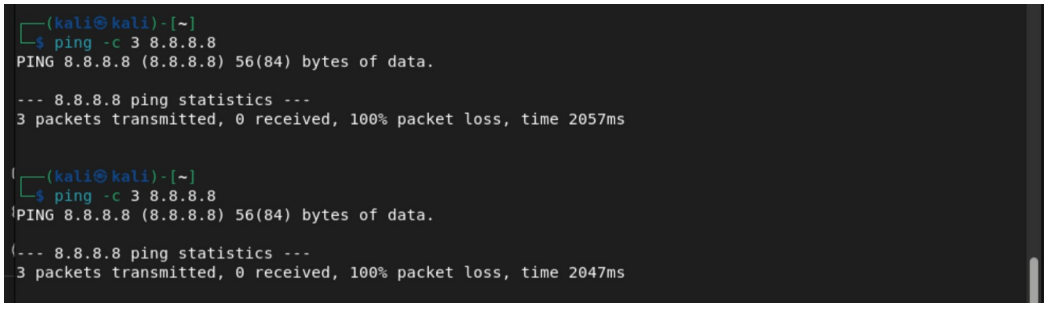


Résultat de nc -zv ftp.gnu.org 21 -w 3 depuis Debian Cliente : connexion expiree (timeout).

Pourquoi le FTP est-il bloque ? Par quelle règle exactement ?

Le FTP utilise le port 21 en TCP, qui ne figure dans aucune des règles d'autorisation créées. Le paquet FTP parcourt donc toute la liste des règles sans trouver de correspondance et atteint la dernière règle : c'est la règle 6, Deny-all explicite, qui bloque finalement le FTP.

5.5. Test isolation de Kali Linux

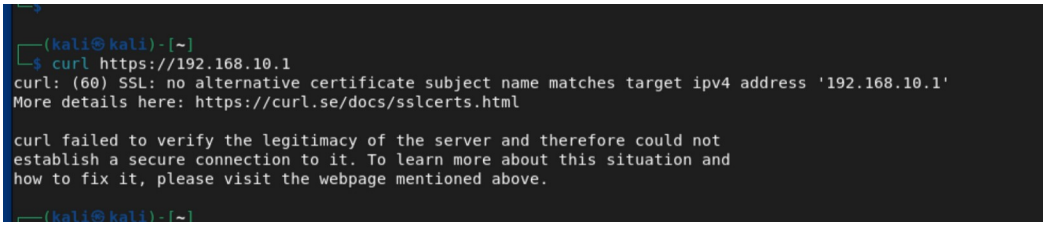


Ping depuis Kali Linux vers 8.8.8.8 : aucune réponse, 100% de perte de paquets.

Expliquez pourquoi Kali est bloque même en essayant de pinger 192.168.10.1 (OPNsense lui-même).

C'est la règle 5, Block Kali_Test, qui en est responsable : elle bloque explicitement tout le trafic sortant de la machine Kali_Test, quelle que soit sa destination, y compris OPNsense lui-même.

5.6. Test accès WebGUI restreint



Tentative d'accès de Kali Linux a https://192.168.10.1 : échec immédiat de la validation du certificat TLS.

> *Cette capture montre une erreur "SSL: no alternative certificate subject name matches target ipv4 address", c'est-a-dire un rejet du certificat autosigne d'OPNsense par curl, et non un timeout ou une connexion refusee. Ce type d'erreur n'est a lui seul pas une preuve suffisante de blocage par le pare-feu, puisqu'elle peut survenir independamment de la règle 5. La preuve la plus fiable aurait été de filtrer les journaux de firewall (Firewall > Log Files > Live View) sur la source Kali_Test et de vérifier que l'entrée porte bien le label associe a la règle 5 (BLOCK - Machine Kali isolée du réseau).*

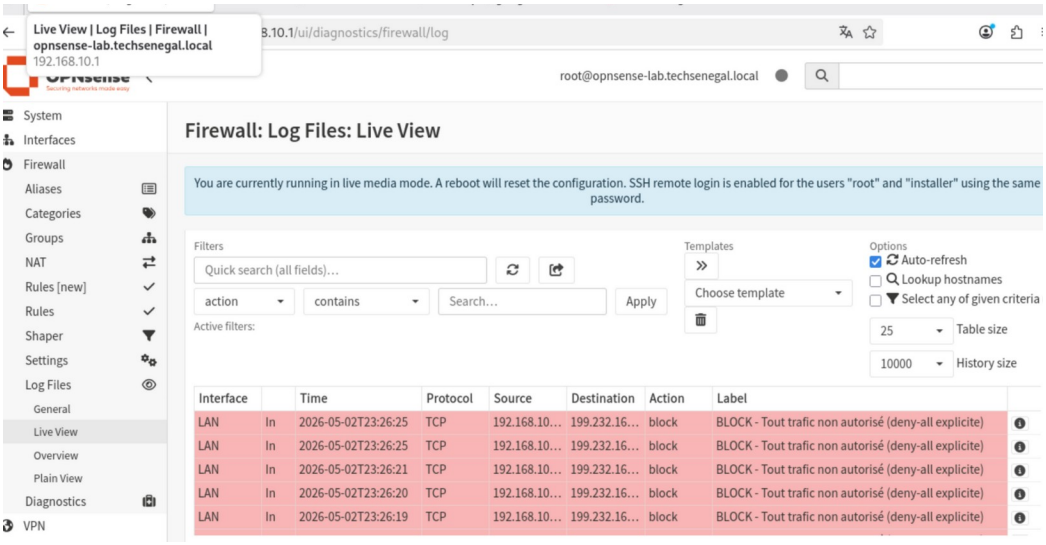
Pourquoi seul le poste 192.168.10.50 peut-il acceder au WebGUI ? Quelle règle le garantit ?

Seul Debian Cliente (192.168.10.50, alias Poste_Admin) peut acceder a l'interface WebGUI d'OPNsense en HTTPS, car c'est la règle 1 qui autorise specifiquement Poste_Admin vers 192.168.10.1 sur le port 443. Aucune autre machine ne beneficie de cette autorisation explicite.

Partie 6 : Analyse des logs de firewall

6.1. Lecture d'une entrée de log

Entrée de log réelle observee dans Firewall -> Log Files -> Live View, avec decodage des principaux champs.



Interface Firewall > Log Files > Live View : entrées bloquées par la règle 6 (deny-all explicite), trafic TCP refuse vers une adresse externe (199.232.16.x).

Le champ Label de chaque entrée identifie directement la règle responsable du blocage (ici "BLOCK - Tout trafic non autorise (deny-all explicite)", c'est-a-dire la règle 6), ce qui permet de diagnostiquer précisément quelle règle a traite un paquet donne sans avoir a deviner. Une entrée générée specifiquement par la règle 5 (Block Kali_Test) porterait le label "BLOCK - Machine Kali isolée du réseau".

6.2. Table des états (firewall stateful)

Qu'est-ce qu'un firewall stateful ? Quel avantage cela apporte-t-il par rapport a un firewall stateless ?

Un firewall stateful (a états) est un pare-feu qui suit l'état des connexions réseau. Il maintient une table des connexions actives (la state table) et prend ses decisions en tenant compte du contexte complet du trafic, et pas seulement de règles statiques appliquées paquet par paquet.

Son principal avantage sur un firewall stateless est qu'il peut autoriser automatiquement le trafic de retour d'une connexion legitime déjà établie, sans qu'il soit nécessaire d'ecrire une règle explicite pour chaque sens de communication, ce qui simplifie la configuration et reduit la surface d'erreur.

Partie 7 : Optimisations et bonnes pratiques

7.1. Bonnes pratiques pour les règles WAN

Deux bonnes pratiques a respecter lors de la création de règles WAN dans OPNsense.

- N'ouvrir que les ports et services strictement nécessaires.
- Quand c'est possible, limiter l'accès a des adresses IP ou plages spécifiques plutôt que de l'autoriser depuis Internet entier.

7.2. Protection contre les scans de ports

Quelles options avez-vous activees dans Firewall > Settings > Advanced pour protéger OPNsense ? Expliquez leur rôle.

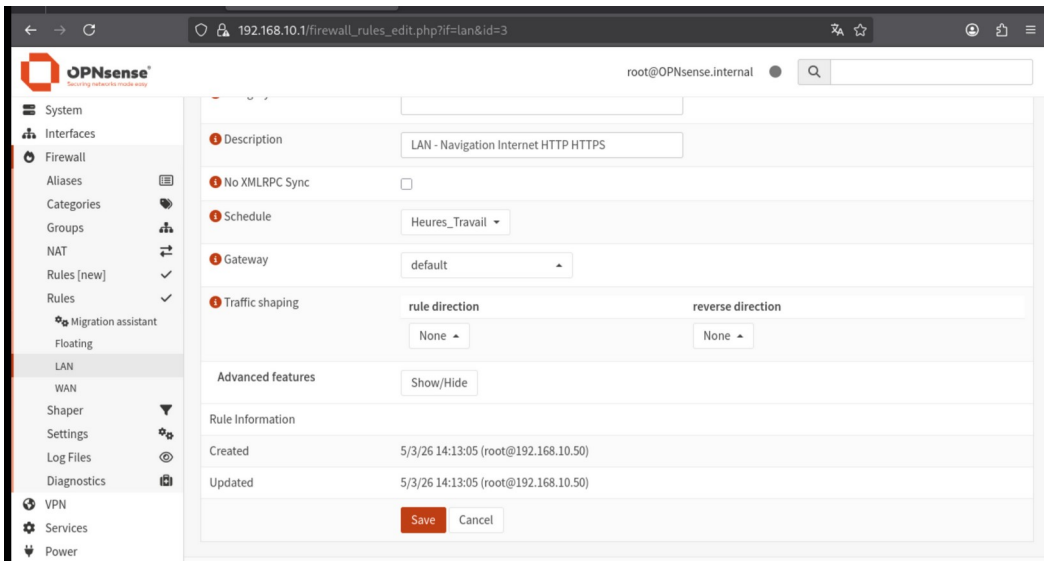
Pour protéger OPNsense, les options Block private networks et Block bogon networks ont été activees : la première bloque les adresses IP privees entrant par l'interface WAN (normalement absentes d'un trafic Internet legitime), et la seconde bloque les plages d'adresses non allouees officiellement (les bogons), souvent utilisees dans des tentatives d'usurpation ou de scan.

Mini-defi

Defi 1 : créneau horaire de navigation

Comment avez-vous configure le schedule Heures_Travail (jours, heures, association a la règle) ?

Dans Firewall -> Schedules -> Add, un schedule nomme Heures_Travail a été cree, couvrant la période du lundi au vendredi, de 08h00 a 18h00, puis associe a la règle de navigation HTTP/HTTPS.



Règle de navigation HTTP/HTTPS avec le schedule Heures_Travail associe.

Comment testeriez-vous que la navigation est effectivement bloquée en dehors des heures de travail ?

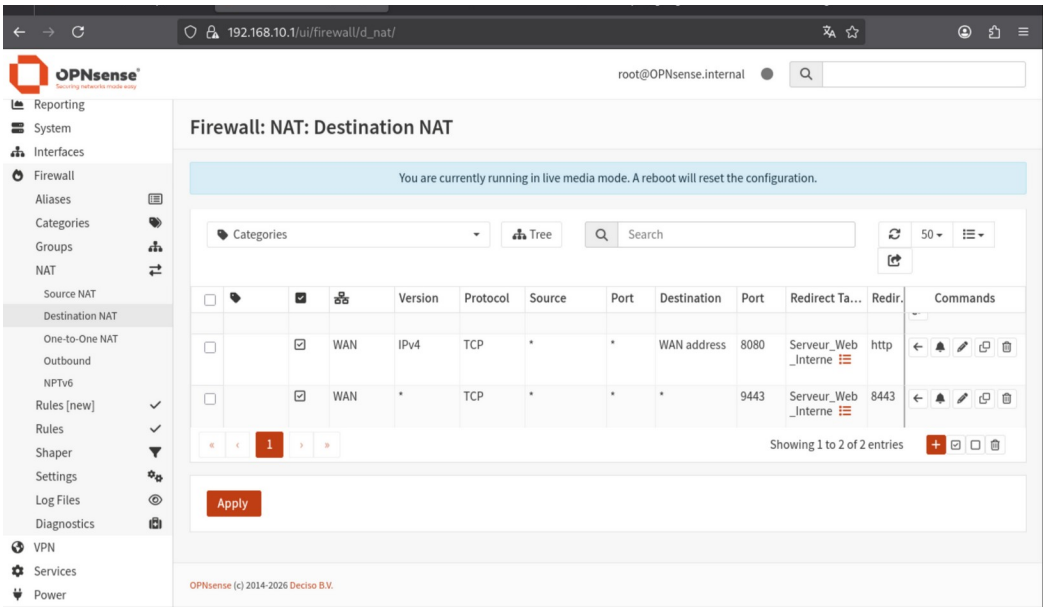
Pour vérifier le comportement de la règle, il faudrait tenter une connexion web depuis Debian Cliente en dehors de la plage 08h00-18h00 (ou modifier temporairement l'horloge système d'OPNsense pour simuler cette plage) et confirmer que la navigation HTTP/HTTPS est alors bloquée, le schedule desactivant la règle de passage en dehors des heures definies.

Defi 2 : second Port Forward (WAN:9443 vers Debian Server:8443)

Decrivez les étapes suivies pour configurer ce second Port Forward.

Un service simple a d'abord été demarre sur le port 8443 de Debian Server. Un nouveau Port Forward a ensuite été cree dans OPNsense, via Firewall -> NAT -> Port Forward, avec les paramètres suivants :

Champ	Valeur
Destination port range	9443
Redirect target IP	Serveur_Web_Interne
Redirect target port	8443
Description	Port Forward, application secondaire TechSenegal



Page Firewall > NAT > Port Forward avec les deux règles (8080 et 9443) visibles.

Expliquez la limitation rencontrée avec le NAT libvirt et comment vous l'avez contournée.

La limitation vient du fonctionnement du NAT de libvirt : les machines virtuelles sont placees derrière un réseau prive (192.168.122.0/24) et sortent vers l'extérieur via l'adresse IP de l'hote grace a la traduction d'adresses réseau. Lors de la configuration d'un service accessible via l'IP WAN (publique ou simulée), la machine hote ne peut donc pas tester cet accès en utilisant cette même IP WAN, puisqu'elle se trouve elle-même du côté prive du NAT libvirt. Le test a été realise en validant l'accès directement depuis une autre machine du réseau capable d'atteindre l'IP WAN d'OPNsense.

Conclusion

Bilan des competences acquises

Les trois competences les plus importantes acquises ou consolidees durant ce TP.

- La création de règles de filtrage precises pour controler le trafic entrant et sortant.
- L'interprétation des logs de firewall pour diagnostiquer un problème de filtrage.
- Le test methodique de l'efficacite des règles a l'aide d'outils réseau de base.

Questions ouvertes

Quels aspects de la sécurité réseau ce TP a-t-il donne envie d'approfondir ? Pourquoi ?

Ce TP a montre que la sécurité réseau ne se limite pas a bloquer ou autoriser du trafic, mais nécessite une reflexion approfondie sur les risques, l'ordre de priorite des règles et les bonnes pratiques de durcissement, ce qui a motive l'envie d'approfondir ces connaissances, notamment sur les mécanismes NAT avances et la détection d'intrusion.